

Ethical Business Plan

Company Name

CerebraTech

Long-Term Vision Statement

Goals

The primary goal at CerebraTech is to become an industry leader in non-invasive neural prosthetic technology by delivering highly accurate, responsive, and accessible systems across socioeconomic and demographic groups. CerebraTech also aims to expand into broader technology applications such as rehabilitation, assistive communication, and enhanced human-computer interaction while maintaining safety, equity, and ethical innovation.

Idea Origination

The idea for CerebraTech came from our desire to provide a solution to real-world healthcare problems that we can use our computer science skills for. We were also interested in the advancement of prosthetic technology that utilizes neural signals to coordinate movement in prosthetic limbs for amputee patients. At the same time, we wanted to provide effective and accessible solutions for underserved populations, such as veterans and low-income patients.

Purpose/Values/Mission

CerebraTech's purpose is to empower individuals with physical disabilities by restoring autonomy and improving their quality of life through computer-brain interface technology. The mission of the company is to design safe, reliable, and equitable neural interface systems that prioritize user privacy, accessibility, and dignity. CerebraTech's core values include responsible innovation, inclusivity, and collaboration with our primary stakeholders.

Key Questions

CerebraTech will guide its development using the following key questions:

- How can CerebraTech maximize positive impact on patients' independence and quality of life while minimizing risk?
- How can CerebraTech ensure its technology remains accessible and equitable across different income levels, races, and backgrounds?

- How can CerebraTech innovate rapidly in the field of brain-computer interfaces while maintaining the highest standards of data privacy, security, and regulatory compliance?

Strategy with Ethical Impacts and Ethical Safeguards

OKR 1 Objective and Key Result

CerebraTech will create safe and reliable rules for handling all neural data collected by its brain-computer interface systems within 12 months of their first use. This can be done by ensuring that all neural data is fully protected with encryption, using the AES-256 encryption method for stored data and the TLS 1.3 protocol for data being sent over CerebraTech's network. We will also conduct at least two independent audits from third-party cybersecurity firms with no critical vulnerabilities found and maintain at least an 85% user trust score regarding our data security practices. Our primary customer base's demographics may include a wide range of people from all ethnic and racial backgrounds, income levels, and ages. Key stakeholders would include the patient, the patient's doctors, insurance providers, CerebraTech engineers, and third-party cybersecurity firms. Patients will rely on the secure handling of highly sensitive neural and personal information, while their doctors need access to patient performance data while maintaining confidentiality. Insurance providers will need to evaluate the cost-effectiveness of our product to provide coverage for patients, and CerebraTech engineers will be responsible for designing and handling data generated by the system. Lastly, cybersecurity firms would be responsible for conducting independent audits to verify our system integrity.

OKR 1 Metrics with Experimentation

We can measure the success of our OKR across a few metrics. By doing internal system audits on all of our data pipelines and finding all of our storage endpoints and possible transmission channels, we can see what percentage of our total data is protected by the required encryption standards. The goal is 100%. Another metric is the number and severity of vulnerabilities found in third-party audits, which can be obtained by hiring two external cybersecurity firms for penetration testing, aiming for no critical vulnerabilities. The last metric we could use to determine the success of our OKR is to conduct a user trust survey among CerebraTech customers on a scale of 0-100 with questions such as

1. I trust CerebraTech to securely handle my neural data.
2. I understand how my data is used and stored.
3. I feel confident my data will not be misused.
4. I am comfortable sharing my data for system improvements.

We could then average the percentage across responses to these questions, with the target being at least 85%.

OKR 1 Ethical Impacts/Issues

Some potential ethical impacts that could arise from this OKR are the privacy risks associated with the neural signals collected as part of the computer-brain interface, as a data breach could expose deeply personal information related to cognitive or emotional function. Users may not fully understand the collection, storage, or usage of their personal or neural information. These issues could stop them from giving their full and informed consent for data use. These problems relate to the case of *Carpenter v. United States*, as the government obtained information from cellphone companies without any warrants establishing probable cause to collect such information [1], meaning that the privacy of patients involved with the technology could be violated by law enforcement if they search any information associated with CerebraTech technology.

Expected Ethical Impact Risk Table

Stakeholder	Financial Risk	Privacy Risk	Conflicting Interest Risk	Violation of Rights Risk
Patient	Mid	High	Mid	High
Doctors	Mid	Mid	Low	Low
Insurance Providers	Mid	Low	High	Low
CerebraTech	High	High	Mid	Mid

- Patient: The financial risk for patients is moderate because they may need to pay out-of-pocket if insurers deny coverage for the prosthetic system due to potential security failures. The privacy risk is high because the system would collect very sensitive neural data that could show personal cognitive states, emotional patterns, or intentions. The conflicting interest risk is moderate because patients will want a product that has the maximum amount of privacy and control, while CerebraTech may want to collect data for improving the system. The risk of violating rights is high because consent could be unclear and the data could be misused, which may violate the patient's rights to privacy and bodily autonomy.

- **Doctors:** Doctors' financial risks are moderate because they could face some liability if they prescribe systems that are insecure and harm patients. The privacy risks are moderate because doctors must comply with HIPAA and keep patient data confidential. The conflicting interest risk is low because doctors may prioritize patient well-being over profit motives. The risk of violating rights is low because any misconduct by CerebraTech will not necessarily affect the doctors.
- **Insurance Providers:** The financial risk for insurance providers is moderate because they could lose money if they cover brain-computer interface systems that break or need to be replaced. The privacy risk for insurance providers is low because they only access summaries of data rather than raw data, so the risk of exposure is lower. The risk of conflicting interests is high because insurance providers may prioritize cost reduction over patient access to prosthetics. The risk of violating rights is low because choosing whether or not to provide coverage to patients is within their rights.
- **CerebraTech:** CerebraTech has a high financial risk because any data breaches could result in lawsuits and reputational damage. The privacy risk is also high because CerebraTech is responsible for all data that passes through the computer-brain interface system, and any failures are the responsibility of the company. The risk of a conflicting interest is moderate because CerebraTech has to collect data to improve future models of the computer-brain interface system while also following privacy limitations. The violation of rights risk is moderate because improper data use or lack of patient consent can violate the patient's rights.

OKR 1 Ethical Safeguards

The first safeguard we will use is end-to-end encryption and a zero-trust security architecture to mitigate the risks associated with data privacy. Cybersecurity experts and compliance officers, whom we could hire from external firms, will design this safeguard. We would implement this safeguard with continuous monitoring systems in our network, such as intrusion prevention systems or intrusion detection systems, and quarterly penetration testing of the company networks. We can measure the effectiveness of this safeguard with the reports gathered from the quarterly penetration testing and auditing of the encrypted data. This is in line with Section 1.7 of the Association for Computing Machinery's Code of Ethics [2], as this supports the defense of confidentiality for our end users. The second safeguard we would use to ensure that patients are aware of the data collected and used by CerebraTech systems is maintaining a transparent data governance framework that provides users with dashboards on their devices that show what data is being collected and how CerebraTech intends to use it, while also allowing users to delete or restrict data as they wish. We can design this safeguard with the help of ethical experts to determine what data is essential for us to keep and what can be

restricted by the user. We can measure the efficacy of this safeguard by surveying how much users trust our data transparency and other metrics on how much the end user checks the data collected by CerebraTech.

OKR 2 Objective and Key Result

Objective: The Cerebratech device will process each user's unique brain signals with a machine learning model that continuously adapts to that individual over time. Patients are expected to show a measurable improvement in prosthetic control over the first six months of adapting.

Key Result: At least 90% of active Cerebratech users will show a statistically significant improvement in functionality between the beginning and end of the adapting and learning period. Functionality will be measured by the number of tasks/functions the user can complete and with what level of difficulty the task is completed or the level of assistance needed to complete the task.

The core idea is that no two people's brains produce identical neural patterns for the same intended movement, and those patterns can also shift over time due to neuroplasticity, fatigue, or mental state. A generic, fixed model would therefore produce inconsistent or frustrating results for many users. The machine learning model continuously learns movement signals paired with actual prosthetic outcomes to tune the decision boundary for each individual profile.

The stakeholders most directly affected by this OKR are patients themselves. The patient population for Cerebratech spans a wide demographic range. Limb loss affects adults of all ages, especially military veterans, and adults with vascular disease or diabetes. Limb loss is agnostic to race and is present among all classes. This demographic spread is significant because it is unclear to what extent these variables indirectly affect the relevant neural patterns. The machine learning model must be trained on data that reflects this diversity; otherwise, its personalization may work well for some groups and poorly for others.

Families and caregivers are indirect stakeholders. If the device works reliably, it reduces their caregiving burden. Case clinicians are participants in the OKR because they give dexterity assessments and interpret progress. Payers are financial stakeholders who will want to see the six-month improvement as a deciding factor for supporting coverage of the program. Regulatory bodies are legal stakeholders that will look for evidence of effectiveness and safety before granting approval. Cerebratech has a commercial interest in this OKR, but also a fiduciary interest in ensuring the model's improvements are genuine and not artificially skewed or biased.

OKR 2 Metrics with Experimentation

To measure utility and user functionality, two metrics will be used: Task Independence Level and Task Difficulty Rating. These two metrics measure if a user can complete a task and how hard the task is. A 5 point ranking system can quantify the independence level with a range of 1 “completely dependent” to 5 “requires no assistance”. A similar ranking system can be used for difficulty with 1 being “extremely frustrating/near impossible”, to 5 being “completely natural, requires little concentration”. This could be further expanded to capture emotional, mental, and physical response by asking the level of concentration required or how fatiguing the task was. Timing the length of the task may also be a secondary indicator of task difficulty.

A standardized test suite of everyday tasks would serve as a litmus test to measure patient functionality. For example, using a utensil to eat, getting into and out of bed, putting on clothes, opening a door, holding a shopping bag, etc. The selection of tasks to be evaluated would be individually curated based on the disability.

OKR 2 Ethical Impacts and Issues

A primary ethical risk is an algorithmic bias in the machine learning model. If the training data used to seed the model is not representative of the full diversity of the user population, the adaptation process may converge more slowly or less completely for underrepresented groups. In practice, this could mean that a White male military veteran whose demographic is overrepresented in early beta testing achieves excellent performance within weeks, while an older African American woman with a diabetic amputation lags behind due to differing neural signals and causation for limb-loss.

A real-world parallel to this risk is found in the case of pulse oximetry bias. Research published in the New England Journal of Medicine found that FDA-cleared pulse oximeters, devices that estimate blood oxygen saturation, overestimated oxygen levels in Black patients compared to White patients at a significant rate. This flaw was rooted in the devices being calibrated primarily on lighter-skinned subjects [3]. Due to the countless confounding variables that may affect neural signaling, it is critical that data is collected from all types of race, ethnicities, lifestyles, and medical histories.

A second ethical issue is data privacy. The personalization process requires the device to continuously collect the user's neural signals, map them to intended movements, and store this data to update the model. Neural data is sensitive. It can potentially reveal motor intentions, emotional states, cognitive patterns, or medical conditions beyond the scope of limb control if collected in volume. Even if raw neural data never leaves the device, the behavioral patterns inferred from it could be commercially valuable and could be targeted by malicious actors. If a user opts into sharing data with Cerebratech for broader model improvement, anonymization provides partial protection to the user. However, even if the method of how to use the anonymized data for financial gain is not evident, “Big Data” is always in high demand and can be sold for a price. For this purpose, user data will never be sold to third parties.

A third issue is consent. The continuous, passive nature of neural data collection means users may not fully understand the extent of the data being gathered. Informed consent for the device is more complex than for a standard medical device because the data being collected comes directly from the brain. Vulnerable populations, such as older adults with cognitive decline or minors, may face challenges in providing meaningful informed consent.

Expected Ethical Impact Risk Table

Stakeholder	Financial Risk	Privacy Risk	Conflicting Interest Risk	Violation of Rights Risk
Patient/User	Mid	High	Mid	High

Stakeholder	Financial Risk	Privacy Risk	Conflicting Interest Risk	Violation of Rights Risk
Cerebratech	High	Mid	High	Low
Clinicians	Low	Low	Mid	Low
Payers/Insurers	High	Low	High	Low
Regulators (FDA)	Low	Low	Mid	Mid

OKR 2 Analysis of Ethical Impact Risk

Patient/User Stakeholder: Financial risk is rated mid because users who are less receptive to the device need additional clinical visits and receive diminished utility from the product. Privacy risk is high because the device collects neural signals on a continuous basis. A breach or unauthorized use of this data could expose personal information about the user. Conflicting interest risk is medium because patients want a device that maximizes their personal functional improvement, while Cerebratech's model improvements may prioritize majority-group accuracy. Violation of rights is high- If underrepresented groups receive inferior adaptation, they are being denied equal benefit from the technology, which constitutes a violation of equitable access rights.

Cerebratech Stakeholder: Financial risk is high because of product performance, if it falls short could trigger regulatory action, tarnished reputation, product recalls, or lawsuits- any of which could be catastrophic for a startup. Privacy risk is mid because Cerebratech handles anonymized neural data on its servers, but needs to protect it from attacks. Conflicting interest risk is high because the company's incentive is to ship a product quickly and demonstrate impressive performance metrics which can conflict with the ethical priorities. Violation of rights risk is low at the company level because the company itself does not have rights that are being violated.

Clinicians Stakeholder: Financial risk is low because clinicians are paid for their services regardless of device performance. Privacy risk is low because clinicians have extremely limited access to relevant data. Conflicting interest risk is mid because clinicians want the best outcome for each patient but may feel financial pressure or incentive from payers or Cerebratech to endorse the device. Violation of rights risk is low.

Payers/Insurers Stakeholder: Financial risk is high because payers who cover device costs are directly exposed to all costs associated with the device. Conflicting interest risk is high because payers want to minimize expenditure while patients and clinicians want the best possible care regardless of cost. Privacy risk and violation of rights risk are both low for payers since they are not exposed to it.

Regulators (FDA) Stakeholder: Financial risk is low because Cerebratech has no financial impact on the regulators. Privacy risk is low since the FDA is a trusted government organization. Conflicting interest risk is low because the FDA has no financial incentive to act a certain way. Violation of rights risk is mid because if the FDA approves a device with demographic bias, it fails to mandate inclusive testing.

OKR 2 Ethical Safeguards

The most important safeguard against algorithmic bias is what we can call a Demographically Stratified Data Collection Protocol. Before the device is ever submitted to the FDA for approval, the machine learning model must be trained on data that actually represents the full range of people who will use it (as best as possible). To achieve this, Cerebratech will recruit a training dataset of participants with diverse representation, age, sex, race, ethnicity, lifestyle, and cause of amputation to contribute a foundation of labeled data. This directly follows guidance from the FDA's 2022 Action Plan for Racial Equity in Medical Devices, which calls on device manufacturers to proactively test and verify that their products perform equally well across racial and ethnic groups [4].

The rollout would happen in phases. First, Cerebratech would collect and label training data across partner clinical sites. The model would then be trained on that data and model training success will be determined by equal functionality across diversity metrics. Data will continue to be collected to close the gap between lagging groups. Finally, the model will enter real world trials where the fairness checks will continue to be run on live user data.

To protect user privacy during the ongoing personalization process, Cerebratech machine learning models are periodically trained on user data, but model state/checkpoint is deleted after updating to the user device. The only persistent copies of the models are always only on the user device. This means there is no central location where anyone could piece together an individual user's neural data.

Cerebratech will address the issue of informed consent through the Cerebratech mobile app. Instead of a long legal document, the app will walk through short, plain-language explanations of what data is collected, where it goes, who can see it, and how to opt out. This encourages consent that is genuine.

OKR 3 objective and key result

The OKR I chose for this report will focus on CerebraTech's data security and encryption. Our main goal is to build a secure data system that protects patient neural data. The three key things that we are focusing on currently are reaching 100% encryption coverage for all stored and transmitted data, completing an FDA submission within 12 months, and also being able to have third party security audits with no critical vulnerabilities being found. The patients who will be using the device are the biggest stakeholder when it comes to this. They are adults and teens between multiple different groups of age, race and income. We predict that the majority will be on medicare or certain veteran benefits with most being lower income. Since these patients are the ones whose neural data is actually being stored they are the ones really at risk with their data that can be damaging.

OKR 3 metrics and experimentation

For the 100% encryption result we want, we will run automated scanning tools that checks all databases and transmission channels on a monthly basis and the company needs to make sure every single place data is stored or sent is protected that way. The tool will generate a pass or fail report for each pathway, and anything that fails gets flagged immediately and will get moved to be handled and fixed by the security team within 24 hours. We will try to have a 100% pass rate for three straight months with no flags. To make sure our device passes the FDA submission we will build up a 12 month roadmap of different check points to cover the clinical testing phase and trials.

OKR 3 Ethical Impacts/Issues

The biggest ethical issue we would have is the risk of patient neural data being accessed, leaked or used without the patient's consent, since the patient's neural data literally shows what is happening inside someone's nervous system, this is our biggest risk. An example could be a breach in CerebraTech's cloud infrastructure which could expose thousands of patients' neural profiles to bad actors, or even law enforcement could attempt to subpoena neural records without a warrant, which raises serious Fourth Amendment issues which the law scenario connects directly to *Carpenter v. United States* (2018). In that case, the Supreme Court ruled that the government collecting cellphone location data from a third party phone carrier without a warrant violated the fourth amendment. Storing neural signal data on its servers puts it in basically the same position as that phone carrier and if law enforcement or anyone else tried to access that data without the patient's knowledge or a warrant, it would be the same kind of violation the Court addressed in *Carpenter* [5]. Neural data can be arguably more sensitive than location history so the privacy concern here is actually stronger.

Stake Holder	Financial Risk	Privacy Risk	Conflicting Interest Risk
Patient	mid	high	mid
CerebraTech	high	low	high
Doctors/clinics	low	mid	mid
FDA	low	low	mid
Family	mid	mid	low

OKR 3 Ethical Safeguards

To address all the risks we need to make sure all the systems are in place. The first safeguard is adding role based access control on top of the existing encryption which the encryption itself will scramble the

data, but it doesn't totally stop someone from accessing the information. We will make sure to have role based access control so that only people with a specific reason or a certain level of clearance can pull patient neural data, for example a software engineer working on the app interface will not have access to neural signal records. Finally I believe that a cybersecurity expert and a healthcare privacy attorney should help design the permission structure[6]. Another safeguard is that we should have clear informed consent process so before we collect any neural data every patient and their family members will need to know exactly what is being collected, where it gets stored, and who can see it and lastly we will have a policy where we only keep the data that we actually need and all other data we don't need older than 90 days will be permanently deleted from all of our systems while also not sharing any of that data with any insurance companies or anyone without the consent of the patient[6] and with all of this we plan to make sure that all areas will be covered to the best of our knowledge and keep improving over time.

References

- [1] ACLU. 2018. *Carpenter v. United States*. Retrieved from <https://www.aclu.org/cases/carpenter-v-united-states>.
- [2] ACM. 2018. ACM Code of Ethics and Professional Conduct. Retrieved from <https://www.acm.org/code-of-ethics>.
- [3] Sjoding, M.W., Dickson, R.P., Iwashyna, T.J., Gay, S.E., and Valley, T.S. 2020. Racial bias in pulse oximetry measurement. *New England Journal of Medicine*. 383, 25, 2477–2478. DOI: <https://doi.org/10.1056/NEJMc2029240>
- [4] U.S. Food and Drug Administration. 2022. FDA Action Plan for Racial Equity: Medical Devices. U.S. Department of Health and Human Services. Retrieved from <https://www.fda.gov/regulatory-information/search-fda-guidance-documents/diversity-action-plans-improve-enrollment-participants-underrepresented-populations-clinical-studies>
- [5] *Carpenter v. United States*, 585 U.S. 296 (2018). Supreme Court of the United States. Retrieved from https://www.supremecourt.gov/opinions/17pdf/16-402_h315.pdf
- [6] W. N. Price II and I. G. Cohen. 2019. Privacy in the age of medical big data. *Nature Medicine* 25, 1 (2019), 37–43. <https://pmc.ncbi.nlm.nih.gov/articles/PMC6376961/>

